

SecureForge Web

Relatório de Postura de Segurança

Gerado em 24/07/2026, 16:48:52

Identificação da aplicação

Gitea

URL: https://demo.gitea.com/

Stack: Go + TypeScript + JavaScript + CSS

Análise: Análise 24/07/2026 — Checklist Essential SecureForge v1.0

Concluída em: 24/07/2026

Gerado por: SecureForge Web (secureforgeweb@gmail.com)

Resumo executivo

42%

Score de postura

14

Total de achados

14

Achados abertos

0%

Taxa de resolução

Achados por severidade

Crítica: 3

Alta: 7

Média: 3

Baixa: 1

Plano de ação priorizado

AUTHZ-03 — Rotas administrativas protegidas

Crítica · Imediata · Aberto · Autorização

Ação recomendada: Exija autenticação + autorização admin em todas as rotas /admin.

INPUT-02 — Queries SQL parametrizadas

Crítica · Imediata · Aberto · Validação de entrada

Ação recomendada: Use ORM ou prepared statements; nunca concatene SQL com input do usuário.

SECRET-02 — Ausência de credenciais no repositório

Crítica · Imediata · Aberto · Proteção de credenciais

Ação recomendada: Execute varredura de segredos e rotacione credenciais expostas.

AUTH-01 — Política de senha mínima

Alta · Curto prazo · Aberto · Autenticação

Ação recomendada: Exigir 8+ caracteres com maiúscula, minúscula, número e especial.

AUTH-03 — Proteção contra força bruta

Alta · Curto prazo · Aberto · Autenticação

Ação recomendada: Implemente rate limit no endpoint de login e bloqueio temporário.

AUTHZ-02 — Princípio do menor privilégio

Alta · Curto prazo · Aberto · **Autorização**

Ação recomendada: Audite papéis e remova acessos desnecessários.

INPUT-01 — Validação server-side

Alta · Curto prazo · Aberto · **Validação de entrada**

Ação recomendada: Implemente validação com schema (Joi/Zod) em todos os endpoints.

INPUT-03 — Sanitização anti-XSS

Alta · Curto prazo · Aberto · **Validação de entrada**

Ação recomendada: Escape output, use CSP e frameworks que sanitizam por padrão.

HEADER-01 — Content-Security-Policy

Alta · Curto prazo · Aberto · **Headers de segurança**

Ação recomendada: Defina Content-Security-Policy adequada ao tipo de aplicação.

HEADER-02 — Strict-Transport-Security

Alta · Curto prazo · Aberto · **Headers de segurança**

Ação recomendada: Configure Strict-Transport-Security em produção.

AUTH-04 — Expiração de sessão

Média · Médio prazo · Aberto · **Autenticação**

Ação recomendada: Defina timeout de sessão e renovação segura de tokens.

ERROR-01 — Sem stack trace em produção

Média · Médio prazo · Aberto · **Mensagens de erro**

Ação recomendada: Retorne mensagens genéricas ao usuário; logue detalhes no servidor.

SURF-01 — Portas e serviços desnecessários

Média · Médio prazo · Aberto · **Superfície de ataque**

Ação recomendada: Desative portas, debug endpoints e serviços não utilizados.

ERROR-02 — Mensagens genéricas ao usuário

Baixa · Baixa · Aberto · **Mensagens de erro**

Ação recomendada: Use mensagens uniformes para falhas de autenticação e validação.

